

VOLT PERFORMANCE

COMMERCIAL RELEASE ROADMAP

Von funktionierender Beta zu einer produktionsreifen iOS-/Android-App

Repo-spezifischer Execution Plan, Security-/Compliance-Gates, Monetarisierung, Store Submission und 30-Tage-Launchplan

Stand: 14. September 2026

Basis: Deep-Research-Audit von <https://github.com/knrds/fitness-tracker>

Zentrale Leitlinie

Der Fitness-Core ist für V1 weit genug. Ab jetzt gilt Feature Freeze: Production Infrastructure + Data Integrity + Payments + Compliance + Distribution + Conversion + Operations.

Hinweis: Diese Roadmap ist technische und organisatorische Release-Planung, keine individuelle Rechts- oder Steuerberatung. Finale deutsche Datenschutz-/AGB-/Verbraucherrechtsfragen sollten vor kommerziellem Launch fachlich geprüft werden.

Inhalt

1. 1. Executive Summary und Release-Urteil
2. 2. Ausgangslage und Zielbild
3. 3. Prioritätsmodell und V1 Non-Goals
4. 4. Zielarchitektur für Production
5. 5. Phasen-Roadmap 00-11
6. 6. Security & Data Integrity Deep Dive
7. 7. Production Backend & AI Coach
8. 8. Privacy, deutsches/EU-Recht und Health Data
9. 9. Exercise Database & Asset Licensing
10. 10. Monetarisierung, Subscriptions und Unit Economics
11. 11. Onboarding, Paywall und Activation
12. 12. Push, Haptik und Audio
13. 13. Analytics, Monitoring, Remote Config und Support
14. 14. Native QA, Accessibility, Performance und Recovery
15. 15. iOS-/Android Store Submission
16. 16. Minimum Commercial Launch Definition
17. 17. Kosten- und Budgetsteuerung
18. 18. Release-Day Runbook und erste 30 Tage
19. 19. Master Go-Live Checklist
20. 20. Offene Entscheidungen
21. 21. Quellen und Audit-Annahmen

1. Executive Summary und Release-Urteil

Das Repository ist deutlich weiter als ein typischer MVP. Laut Deep-Research-Audit sind Workout-/Plan-/History-/Measurement-/Achievement-/Coach-Funktionen bereits weit fortgeschritten, die App arbeitet offline-first mit React Native/Expo, SQLite und einer getrennten Domain-Schicht. Die aktuelle Projektdokumentation nennt eine umfangreiche Testsuite und gleichzeitig ausdrücklich noch offene Production-/Release-Gates.

Release-Urteil

Produktfunktionalität: V1 weitgehend vorhanden. Commercial Readiness: noch nicht erreicht. Die größten Risiken liegen nicht in fehlenden Trainingsfeatures, sondern in nativer Release-Abnahme, Security/Data Integrity, Production Backend, Subscriptions, Datenschutz/Lizenzen, Monitoring und Store-Prozessen.

Bereich	Audit-Stand	Release-Risiko
Workout/Plans/History/Measurements	weit fortgeschritten	Niedrig
Native iOS/Android Release	nicht final abgenommen	Kritisch
Cloud Sync/RLS	unvollständig abgenommen	Kritisch
Account Delete/Export	offen bzw. unvollständig	Kritisch
Coach Production Security	funktional, Hardening offen	Kritisch
Subscriptions/Paywall	noch aufzubauen	Kritisch
Onboarding	fehlt/noch aufzubauen	Hoch
Privacy/Legal	noch nicht releasefertig	Kritisch
Exercise DB License Proof	nicht belastbar dokumentiert	Kritisch
Push/Haptik/Audio	teilweise vorhanden	Mittel
Monitoring/Analytics	Production-Layer unklar	Hoch
Accessibility/Device QA	offen	Hoch

Empfohlene Projekthypothese: Ein seriöser iOS-first Commercial Launch ist erreichbar, wenn der Scope eingefroren bleibt und die Roadmap konsequent P0-first abgearbeitet wird. Der Zeitplan hängt primär von echten Device-Builds, Sync/RLS-Härtung, Provider-/Lizenzfragen und Store-/Legal-Abhängigkeiten ab - nicht von weiteren Features.

2. Ausgangslage und Zielbild

Der Audit beschreibt eine Offline-first Mobile-App mit Expo/React Native, lokaler SQLite-Persistenz, Zustand-basierten Projektionen und einer React-unabhängigen Domain-Schicht. Der Coach läuft über einen eigenen API-Handler und OpenRouter bzw. nachgelagerte Modelle. Supabase ist für Auth/Cloud-Sync vorgesehen. Diese Grundarchitektur ist für V1 sinnvoll und sollte nicht vor Release ersetzt werden.

- Native App läuft auf dem Gerät; es ist kein klassischer "Server, auf dem die ganze App läuft" nötig.
- Lokale SQLite-Daten bleiben für schnelles und offline-fähiges Tracking zentral.
- Supabase übernimmt Auth, user-owned Cloud-Daten, RLS, Sync-Metadaten und später Entitlement-/Push-/Usage-Daten.
- Das Coach-Backend bleibt serverseitig, damit Provider-Secrets niemals im Client liegen.

- Subscription-Entitlements müssen serverseitig vertrauenswürdig werden; ein lokales isPremium-Flag reicht nicht.
- Production benötigt getrennte dev/staging/prod-Umgebungen, Backups, Migrationsdisziplin, Monitoring und Incident-Steuerung.

Kein unnötiger Rewrite

Vor V1 keinen Wechsel zu Firebase/AWS/eigenem komplett neuen Backend, keinen neuen State-Management-Stack und keinen Neubau des Trackers. Das Risiko wäre höher als der Nutzen.

3. Prioritätsmodell und V1 Non-Goals

P0: Launch-Blocker. Ohne Abschluss kein kommerzieller Store-Release.

P1: Vor Launch stark empfohlen. Kann nur mit dokumentierter Risikoakzeptanz verschoben werden.

P2: Kurz nach Launch. Sollte bereits als Backlog mit Messkriterium geplant sein.

P3: Später. Kein V1-Grund, den Release zu verzögern.

V1 Non-Goals

- Nutrition Tracker
- Running/GPS
- Social Feed/Community
- Marketplace
- User-to-user Chat
- komplexe Challenges/Leaderboards
- vollständiges Wearable-Ökosystem
- Web-Dashboard
- Coach Marketplace

Diese Bereiche können später sinnvoll sein, aber sie verzögern aktuell Umsatz, Review und Sicherheitsreife. Die vorhandene Story - Training, Programme, Exercise Library, History, Progress, Measurements, Gamification und AI Coach - reicht für eine kommerzielle V1.

4. Zielarchitektur für Production

Die Zielarchitektur bleibt bewusst pragmatisch: Mobile-first, offline-first und serverseitige Kontrolle nur dort, wo sie für Auth, Sync, AI, Payments und Operations nötig ist.

Schicht	V1 Verantwortung	Wichtige Controls
Mobile / Expo RN	UI, Workout Session, Offline Tracking, lokale History-Projektion	keine Secrets; sichere Token; lokale DB Migrationen; Accessibility
SQLite	Offline Source of Truth / schnelle lokale Persistenz	atomic writes; migrations; backup/file protection; recovery
Supabase Auth/Postgres	Identität, Cloud Sync, user-owned data, RLS	deny-by-default RLS; revisions; tombstones; backups/PITR
Coach API	Auth, entitlement, quota, context minimization, provider calls	HTTPS; distributed rate limits; spending guard; logging hygiene

OpenRouter/Provider	LLM/Vision/Transcription	approved provider list; retention/data-policy review; no random routing
Revenue/Stores	StoreKit/Play Billing, entitlement lifecycle	server/webhook validation; restore; refund; grace/expiry
Push	APNs/FCM/Expo Push	preferences; frequency caps; device token lifecycle
Observability	crash/error/API/sync/subscription/AI spend	no sensitive payloads; alerts; kill switches

Environments

- Development: lokale oder Testdaten, separate Keys/DB.
- Preview/Staging: echte native Builds, Sandbox Purchases, Test-Providerbudgets.
- Production: separate Supabase-/Provider-/Revenue-/Push-Credentials; kein Sharing mit Testumgebung.

Secrets dürfen nur serverseitig liegen: OpenRouter/Provider Secret Keys, Supabase Service Role, Apple/Google private credentials, webhook secrets und DB-admin credentials. Clientseitig dürfen nur ausdrücklich öffentliche/publishable Konfigurationen stehen.

5. Phasen-Roadmap 00-11

Phase 00 - Release Control, Feature Freeze & Baseline

Ziel: Den aktuellen Beta-Stand einfrieren, reproduzierbar machen und eine belastbare Ausgangsbasis schaffen.

Warum: Die App ist funktional, aber laut Audit noch nicht Production-/Commercial-ready. Ohne Baseline führt parallele Agentenarbeit schnell zu Regressionen und Scope Creep.

Planungsfenster: Tag 0-2

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
00.01	P0	M	Repository-Baseline festhalten	Aktuellen Main-Stand, Build-Konfigurationen, Umgebungsvariablen-Namen, Tests und bekannte Issues dokumentieren. Keine Secrets kopieren.	Baseline-Dokument enthält Commit/Stand, Testkommandos, Buildprofile, offene Blocker und Verantwortlichkeiten.
00.02	P0	S	V1 Feature Freeze definieren	Nutrition, Running/GPS, Social Feed, Marketplace, Wearables und andere große neue Systeme explizit aus V1 herausnehmen.	V1 Scope und Non-Goals sind im Repo dokumentiert und werden vom Agenten respektiert.
00.03	P0	S	Release-Statusdatei anlegen	docs/release/EXECUTION_STATUS.md als zentrale Quelle mit Work-Package, Status, Blocker, Evidenz und nächstem Schritt.	Jede weitere Aufgabe wird dort mit Datum, Ergebnis und Evidence aktualisiert.
00.04	P1	S	Branch- und Commit-Regeln definieren	Kleine reversible Änderungen; keine Mega-Refactorings; pro Work Package getrennte Commits/PRs.	Agent kann jederzeit auf letzten grünen Stand zurückrollen.
00.05	P1	M	Automatisierte Tests als Gate fixieren	Vor Änderung Test-Suite ausführen; laut Audit bestehen bereits 246 Tests. Testkommandos	Vorher/Nachher-Testresultat dokumentiert; keine stillen Regressionen.

				stabilisieren.	
--	--	--	--	----------------	--

Agent kann: Repo inspizieren, Dokumentation anlegen, Tests ausführen, Scope-Dateien und Status-Tracker pflegen.

User/extern: Finale Produktbezeichnung/Branding bestätigen, falls Volt/Volt Performance noch nicht endgültig entschieden ist.

Phase Gate

Kein Feature-Code aus späteren Phasen startet, bevor Baseline, Scope und Status-Tracker existieren.

Phase 01 - Native Release Foundation & Store Identity

Ziel: Echte signierte iOS-/Android-Builds auf realen Geräten herstellen und die dauerhafte Store-Identität festlegen.

Warum: Der Deep-Research-Audit markiert echte Device Builds, Apple Developer Enrollment, EAS-Verknüpfung und native Release-Gates als offen.

Planungsfenster: Tag 1-7

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
01.01	P0	S	Apple Developer Program abschließen	Mitgliedschaft und richtige Account-/Organization-Strategie klären.	App kann signiert, über TestFlight verteilt und später eingereicht werden.
01.02	P0	S	Google Play Developer Account vorbereiten	Accounttyp, Identitätsverifikation und ggf. 12-Tester/14-Tage-Anforderung frühzeitig klären.	Play Console ist aktiv; notwendiger Closed Test ist terminiert oder gestartet.
01.03	P0	M	Finale App Identity festlegen	Display Name, Bundle Identifier, Android Package, URL Scheme, Support-/Privacy-/Terms-URLs finalisieren.	Identity ist in Expo/EAS und Store-Konfiguration konsistent.
01.04	P0	M	EAS Projekt und Buildprofile validieren	development/preview/production sauber trennen; keine Produktionssecrets in Client-Config.	iOS- und Android-Builds laufen reproduzierbar.
01.05	P0	M	Echter iPhone Development Build	Fresh install, cold start, Workout, History, Measurements, Coach smoke-test.	Smoke-Test auf physischem iPhone bestanden; Ergebnisse dokumentiert.
01.06	P0	M	Echter Android Development Build	Analog iOS, mindestens ein reales Gerät unterschiedlicher DPI/Version.	Smoke-Test auf realem Android bestanden.
01.07	P1	S	iPad-Support bewusst entscheiden	Entweder vollständig testen oder Zielgeräte/Layouts entsprechend einschränken.	Keine ungeprüfte Tablet-Versprechung im Store.

Agent kann: Expo/EAS-Konfiguration prüfen und vorbereiten, Buildfehler beheben, Smoke-Test-Checklisten erzeugen.

User/extern: Apple-/Google-Accounts, Identitätsprüfung, Zahlungsdaten, Zertifikats-/Credential-Freigaben.

Phase Gate

Mindestens ein realer iOS- und Android-Build ist grün; Bundle/Package-Identität ist final.

Phase 02 - Security, Auth & Data Integrity Hardening

Ziel: Datenverlust, Cross-Account-Zugriff und unsichere Token-/Sync-Flows vor Monetarisierung ausschließen.

Warum: Fitnesshistorie und Measurements sind Vertrauensdaten. Der Audit nennt sichere Token-Speicherung, RLS, Cloud-Sync, Revisionen/Tombstones, Account-Löschung und Dependency-Findings als offene Release-Gates.

Planungsfenster: Woche 1-3

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
02.01	P0	M	Secret-Scan inkl. Git-History	OpenRouter, Service Role, Provider Keys, private Credentials und alte Commits prüfen; kompromittierte Keys rotieren.	Dokumentierter Scan ohne aktive Secrets im Client oder Git-Verlauf.
02.02	P0	M	Secure Token Storage	Refresh-/Session-Tokens auf iOS Keychain und Android Keystore-backed Secure Storage migrieren.	Tokens liegen nicht in normalem AsyncStorage/MMKV; Migration getestet.
02.03	P0	L	RLS vollständig härten	Für jede user-owned Supabase-Tabelle Policies definieren, deny-by-default prüfen und Cross-Account-Integrationstests schreiben.	Account A kann niemals Daten von Account B lesen/ändern/löschen.
02.04	P0	L	Sync-Konflikte robust machen	Revisionen, Tombstones, Pull/Push-Konflikte, idempotente Outbox und Retry-Verhalten vervollständigen.	Offline/online und Zwei-Geräte-Szenarien erzeugen keinen stillen Datenverlust.
02.05	P0	M	Transaktionale Cloud-Befehle	Mehrschrittige kritische Mutationen serverseitig/RPC atomar machen.	Keine halbfertigen Programme/Workouts bei Request-Abbruch.
02.06	P0	M	Guest-/Installations-ID finalisieren	Lokale Besitzverhältnisse und Migration Guest -> Account eindeutig definieren.	Keine Datenvermischung bei Login/Logout/Accountwechsel.
02.07	P0	M	Account Deletion End-to-End	Cloud Rows, Storage, Coach History, Sessions/Auth User und lokale Daten nach Bestätigung löschen.	In-App Delete Account erfüllt Store- und Datenschutzanforderungen; E2E-Test vorhanden.
02.08	P0	M	Vollständiger Datenexport	Maschinenlesbarer JSON-Export plus sinnvolle CSVs für Workouts/Measurements.	Export enthält alle nutzerbezogenen Produktdaten und wird getestet.
02.09	P0	M	Dependency-Audit triagieren	Die dokumentierten Findings nach Production Reachability, Fix, Mitigation, akzeptiertem Restrisiko klassifizieren.	Kein ungeklärtes High-Risk-Produktionsfinding bleibt offen.
02.10	P1	M	iOS Backup/File Protection prüfen	SQLite/WAL/SHM und sensible Dateien gegen ungeeignete Cloud-Backups prüfen; OS File Protection nutzen.	Dokumentierte Backup-Strategie für Fitness-/Gesundheitsdateien.

Agent kann: Codeanalyse, Tests, RLS-Testharness, Storage-Migration, Export-/Delete-Flows und Security-Dokumentation implementieren.

User/extern: Rotation realer Provider-/Service-Keys, Supabase-Productionzugang, Risikoakzeptanz bei nicht patchbaren Dependencies.

Phase Gate

Data-integrity Testmatrix und Cross-Account-RLS-Test sind grün; Delete/Export funktionieren real.

Phase 03 - Production Backend & AI Coach Hardening

Ziel: Den funktionierenden Coach in einen kontrollierten, abrechenbaren und datenschutzbewussten Produktionsdienst verwandeln.

Warum: Der Audit bestätigt ein sinnvolles Backend-Prinzip, aber aktuell kein belastbar abgenommenes Production-Backend und nur prozesslokales Rate Limiting.

Planungsfenster: Woche 2-4

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
03.01	P0	M	Production HTTPS Endpoint deployen	Bestehenden /api/coach-chat-Flow auf geeigneter Hosting-Umgebung bereitstellen; Timeouts/Body-Limits/Region prüfen.	Native App kann ausschließlich über HTTPS produktiv auf Coach zugreifen.
03.02	P0	M	Serverseitige Auth erzwingen	Jeder Request validiert Supabase Session; keine anonyme Provider-Nutzung.	Ungültige/abgelaufene Tokens führen zu 401/403 ohne Providerkosten.
03.03	P0	L	Distributed Rate Limiting	Zentralen Counter via Redis/Upstash oder Postgres/RPC statt process-local Map.	Mehrere Serverinstanzen teilen Limits korrekt.
03.04	P0	L	AI Usage Ledger & Budget Guard	Text/Vision/Audio getrennt zählen, geschätzte Kosten persistieren, User-/Tages-/Monats-/Globalbudgets.	Ein einzelner Account kann kein unkontrolliertes Kostenereignis auslösen.
03.05	P0	M	Premium Entitlement Gate	Backend prüft aktives Volt-Pro-Entitlement bevor kostenintensive Premium-AI ausgeführt wird.	Manipuliertes lokales isPremium reicht nicht aus.
03.06	P0	M	Provider Policy Lock	Freigegebene Provider/Modelle explizit konfigurieren; Datenschutz-/Retention-Entscheidungen dokumentieren; kein ungeprüftes Random-Routing.	Jeder produktive Modellpfad ist rechtlich/technisch freigegeben.
03.07	P0	M	Context Minimization	Pro Query nur notwendige Profile/Workouts/Measurements senden.	Tokenkosten und Datenexposition sind messbar reduziert.
03.08	P0	M	Sensitive Logging entfernen	Keine Prompts, Body Measurements, Tokens, Bilder oder komplette Coach-Texte in Standardlogs.	Logs enthalten technische IDs/Latency/Errorcodes ohne sensitive Payload.
03.09	P0	S	Remote Kill Switch	Coach serverseitig deaktivierbar ohne App-Update.	Incident kann sofort gestoppt werden.
03.10	P1	M	Provider Fallback &	Definierter Fallback nur	Ausfälle erzeugen

			Circuit Breaker	zu freigegebenen Providern; Timeout/Retry begrenzen.	kontrollierte UX statt Retry-Sturm.
03.11	P1	M	AI Safety Guardrails	Fitness/Wellness Scope, keine Diagnose/Therapie, verletzungsbezogene Eskalation, keine extremen gefährlichen Trainingsratschläge.	Testset mit problematischen Prompts besteht.

Agent kann: Backend-Code, Quota-Layer, Entitlement-Schnittstelle, Context Builder, Logging und Tests umsetzen.

User/extern: Provider-Accounts/DPAs/Vertragsentscheidungen, Budgetgrenzen und finale Liste freigegebener Modelle.

Phase Gate

Coach ist auth-, quota-, entitlement- und cost-gated; keine Secrets im Client; Kill Switch getestet.

Phase 04 - Privacy, Legal, Health Data & Licensing

Ziel: Alle für Deutschland/EU und Stores relevanten Daten-, Vertrags- und Rechtsfragen vor Einreichung beweisbar machen.

Warum: Der Audit stuft Exercise-DB-Provenienz, AI-Datenweitergabe, Art.-9-Risiko, Account-Löschung, Privacy-Labels und Asset-Rechte als echte Launch-Blocker ein.

Planungsfenster: Parallel Woche 1-5

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
04.01	P0	M	Dateninventar/Data Map	Für jede Datenkategorie Zweck, Rechtsgrundlage, Speicherort, Empfänger, Drittlandtransfer, Retention und Löschung dokumentieren.	Eine zentrale Data Map speist Privacy Policy, Apple Privacy und Google Data Safety.
04.02	P0	M	Health-Data Assessment	Measurements, Workout-Strength-Daten, Fotos/Audio und abgeleitete Profile auf DSGVO-Art.-9-Relevanz bewerten.	Dokumentierte Einstufung und Schutzmaßnahmen; Rechtsprüfung markiert.
04.03	P0	M	AI Consent Flow	Vor erster Third-party-AI-Verarbeitung klar informieren und Einwilligungs-/Kontrollmechanismus in App vorsehen.	Consent ist versioniert, widerrufbar und technisch durchgesetzt.
04.04	P0	L	Exercise DB Provenance	Exakte Quelle, Commit/Version, Lizenz, Media-Lizenz, Attribution und Importhistorie feststellen.	Kein kommerzieller Release, solange Herkunft/Lizenz ungeklärt ist.
04.05	P0	M	Asset License BOM	Anatomie, Übungsbilder/-animationen, Icons, Fonts, Sounds, Illustrationen, Libraries in THIRD_PARTY_NOTICES/Software BOM erfassen.	Für jedes Asset gibt es Quelle, Lizenz und Commercial-Use-Nachweis.
04.06	P0	M	Privacy Policy + Impressum + Terms vorbereiten	Deutsche/EU Texte mit App-spezifischen Datenflüssen und	Store-URLs existieren und App verlinkt Legal-Bereich.

				Subscription-/AI-Regeln; in App und Web erreichbar.	
04.07	P0	M	Processor/DPA Register	Supabase, Hosting, OpenRouter/Provider, Analytics, Crash, RevenueCat, E-Mail etc. mit AVV/DPA, Region und Subprozessoren.	Kein produktiver Dienst ohne dokumentierte Vertrags-/Transferbasis.
04.08	P0	M	Retention & Deletion Schedule	Dauer und Löschtrigger je Datentyp definieren, inklusive Backups/Logs.	Löschung ist technisch und organisatorisch konsistent.
04.09	P1	M	DPIA/Risikoanalyse	Schlanke Datenschutz-Folgen-/Risikoanalyse für Fitness-/AI-Daten erstellen.	Risiken, Eintritt, Schaden und Mitigation dokumentiert.
04.10	P1	S	AI Transparency Text	Klar kennzeichnen, dass Coach KI ist und keine medizinische Diagnose/Therapie ersetzt.	UI- und Terms-Text konsistent.
04.11	P1	M	External Legal Review	Deutscher IT-/Datenschutzjurist prüft Privacy, Terms, Art.-9-Ansatz, AI Consent und Subscription-Texte.	Freigabe/Änderungsliste archiviert.

Agent kann: Data Map, technische Datenschutzhooks, Consent-Versionierung, Lizenzinventar und Draft-Dokumentation erstellen.

User/extern: Vertragsannahme, Rechnungen/Lizenzen bereitstellen, Unternehmens-/Impressumsdaten, finale Rechtsberatung und Freigabe.

Phase Gate

Keine ungeklärte Datenquelle/Lizenz; Legal-URLs live; Store-Disclosure-Daten aus derselben Data Map ableitbar.

Phase 05 - Subscriptions, Revenue & Entitlements

Ziel: Native Abos korrekt, wiederherstellbar und serverseitig vertrauenswürdig implementieren.

Warum: Für digitale Premium-Funktionen sind auf iOS StoreKit/IAP und auf Android grundsätzlich Play Billing der risikoärmste V1-Weg. Stripe gehört nicht als primärer In-App-Payment-Flow in diese V1.

Planungsfenster: Woche 3-5

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
05.01	P0	S	Produktmodell festlegen	Free vs Volt Pro finalisieren; Export/Delete/Privacy niemals paywallen.	Eine eindeutige Feature-Matrix existiert.
05.02	P0	S	Produkte definieren	Monat und Jahr, Trial, Product IDs, Länder/Preise und Intro Eligibility.	Store-Produkte in App Store Connect/Play Console angelegt.
05.03	P0	M	RevenueCat oder äquivalente Abstraktion integrieren	Entitlement volt_pro; Apple/Google Produkte mappen; keine geheimen Serverkeys im Client.	Purchase-/Restore-Flows funktionieren in Sandbox/Test.
05.04	P0	M	Serverseitige Entitlements spiegeln	Webhook -> Backend/Supabase; Status, Expiry, Product, Platform, Original	Coach und Premium-API vertrauen serverseitigem Entitlement.

				Transaction/User Mapping.	
05.05	P0	M	Subscription Lifecycle testen	Trial, Purchase, Restore, Renewal, Cancel, Expiry, Billing Retry/Grace, Refund und Accountwechsel.	Testmatrix vollständig dokumentiert.
05.06	P0	M	Manage Subscription & Restore	Native Links/SDK-Flows in Settings und Paywall.	Nutzer können Käufe wiederherstellen und Aboverwaltung öffnen.
05.07	P0	S	Paywall-Rechtstexte korrekt	Tatsächlich belasteter Gesamtpreis, Trialdauer, Renewal, Restore, Terms, Privacy.	Kein irreführender Monatsäquivalent-Preis als Hauptpreis.
05.08	P1	M	Unit Economics Modell	Storefee, VAT, AI Kosten, Hosting, Support und Refunds je zahlendem Nutzer modellieren.	Definierter maximaler AI-Cost/paid-user und Zielmarge.

Agent kann: SDK-/Entitlement-Code, Paywall-Backend-Hooks, Testharness, Webhook-Handler und Feature-Gating implementieren.

User/extern: Store Agreements, Banking/Tax, Preisentscheidung, RevenueCat Account/Keys, Apple/Google Product Setup.

Phase Gate

Kein Premium-Zugriff ohne gültiges serverseitiges Entitlement; vollständiger Subscription-Lifecycle getestet.

Phase 06 - Onboarding, Activation & Paywall UX

Ziel: Neue Nutzer schnell zum ersten Wertmoment führen, relevante Daten freiwillig erfassen und dann fair monetarisieren.

Warum: Die Kern-App ist fertig genug; der kommerzielle Funnel fehlt. Onboarding soll personalisieren, nicht den Nutzer mit einem Tutorial erschlagen.

Planungsfenster: Woche 4-6

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
06.01	P0	M	Onboarding State Machine	Versioniertes, resumierbares Onboarding mit Skip/Back und migrationssicherem completed_version-Feld.	Onboarding kann abgebrochen und korrekt fortgesetzt werden.
06.02	P0	M	Goal/Experience/Frequency/Equipment erfassen	Nur produktrelevante Felder; sensible Körperdaten optional und mit Zweckhinweis.	Datensparsame Profileingabe ohne unnötige Zwangsfelder.
06.03	P0	M	Personalized Result Screen	Aus Eingaben konkreten Nutzen zeigen, bevor Paywall erscheint.	Nutzer versteht, wie Volt seine Auswahl nutzt.
06.04	P0	M	Paywall nach Value Reveal	Jahresabo primär, Monatsabo sekundär, Trial klar, Continue Free sichtbar falls Freemium-Strategie gewählt.	Paywall ist transparent und Store-konform.
06.05	P0	M	Guest Mode erhalten	Lokales Tracking ohne erzwungenen Account; Account erst für Sync/Backup/Coach/Premium wenn Produktstrategie so bleibt.	First workout ist ohne unnötigen Login möglich.

06.06	P1	M	Contextual Permissions	Notifications/ Microphone/Photos erst unmittelbar vor Nutzen erklären und dann Systemdialog öffnen.	Keine Permission Wall beim ersten Start.
06.07	P1	M	Empty/Error/Offline States	History, Coach, Sync, Subscription, Network und leere Programme mit klaren Next Actions.	Keine Sackgassen oder technische Rohfehlermeldungen.
06.08	P1	S	Onboarding Analytics	started, step_completed, completed, paywall_viewed, trial_started ohne Health-Daten als Event Properties.	Funnel ist messbar.

Agent kann: Onboarding/Paywall UI, State Machine, Analytics Events und Permission Pre-prompts implementieren.

User/extern: Finale Pricing-/Free-Pro-Strategie, Copy/Brand-Ton und ggf. Designfreigabe.

Phase Gate

Neuer Nutzer kann von Install -> Onboarding -> erstes Workout bzw. Trial ohne Sackgasse gelangen.

Phase 07 - Push Notifications, Haptics & Audio

Ziel: Die bereits visuell starke App auch nativ fühlbar machen, ohne sie nervig oder spammy zu machen.

Warum: expo-haptics ist laut Audit vorhanden; Push fehlt, Audio nutzt einen zu modernisierenden Pfad. Diese Schicht verbessert Retention und native Qualität, ist aber nach P0-Sicherheit einzuordnen.

Planungsfenster: Woche 5-6

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
07.01	P1	M	Notification Infrastructure	expo-notifications/ APNs/FCM bzw. Expo Push sauber integrieren; Device Tokens pro User+Device speichern.	Push kann auf Testgeräten zugestellt und invalidierte Tokens bereinigt werden.
07.02	P1	M	Local Notifications	Rest Timer und geplante Workout Reminder lokal, wo kein Server nötig ist.	Funktioniert offline und benötigt keine unnötige Backend-Abhängigkeit.
07.03	P1	M	Server Push	Re-engagement/Coach-/ Lifecycle-Nachrichten mit Frequency Caps und Preference Checks.	Kein Versand ohne passende Opt-ins/Settings.
07.04	P1	S	Notification Preference Center	Workout, Rest Timer, Progress/Coach, Product/Others separat.	Marketing ist separat opt-in/abschaltbar.
07.05	P1	S	Haptic Service	selection/action/ success/warning/error zentral kapseln und sparsam verwenden.	Konsistente Haptik an Set Complete, PR, Workout Complete, destructive actions.
07.06	P1	M	Audio Service	Rest-complete, PR und Workout-complete Sounds; Silent Mode/Settings respektieren; Migration vom alten Audio-Stack planen.	Sounds können global deaktiviert werden und sind nicht aufdringlich.
07.07	P2	S	Notification Experimentation	Nach Launch Timing und Frequenz anhand Retention testen.	Keine willkürliche Push- Flut; Experimente haben Holdout/Metrik.

Agent kann: Notification/Haptic/Audio-Code, Preference Model und Tests implementieren.

User/extern: APNs/FCM Credentials, finale Copy für Marketing Push und Opt-in-Strategie.

Phase Gate

Alle Notifications respektieren Consent/Preferences; haptisches/audio Feedback ist global abschaltbar.

Phase 08 - Analytics, Crash Monitoring, Remote Config & Support

Ziel: Produktion beobachtbar machen, ohne sensible Fitnessdaten in Telemetrie zu leaken.

Warum: Ohne Crash-/API-/Sync-/Subscription-Monitoring fliegst du nach Launch blind. Gleichzeitig dürfen Health-/Coach-Inhalte nicht in generischen Analytics landen.

Planungsfenster: Woche 4-7

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
08.01	P0	M	Crash/Error Monitoring	JS/native crashes, API 5xx, sync failures, migration failures und subscription webhook errors erfassen.	Crash-free und Fehlerraten sind sichtbar; Payloads sind datensparsam.
08.02	P0	M	Operational Alerts	Coach error rate/latency, global AI spend, webhook failures, DB errors mit sinnvollen Schwellen.	Kritische Vorfälle erzeugen Alerts statt erst Nutzerbeschwerden.
08.03	P1	M	Analytics Taxonomy	Install, onboarding, first_workout, second_workout, trial, paid, churn, coach usage, D1/D7/D30.	Event Dictionary dokumentiert; keine Gewichte/Coachtexthe als Properties.
08.04	P1	M	Remote Config/Feature Flags	coach_enabled, paywall_variant, notification_campaign etc. serverseitig kontrollierbar.	Kritische Features können ohne App-Review deaktiviert werden.
08.05	P1	S	Support/Feedback Path	In-App Support, FAQ, Bug report mit Appversion/Device aber ohne automatische sensible Inhalte.	Nutzer erreicht Support in <=2 Taps aus Settings.
08.06	P1	S	Review Prompt Policy	Store Review Prompt nach positivem Moment und nur selten.	Kein Prompt direkt nach Fehler/Abbruch.

Agent kann: Monitoring SDKs datensparsam integrieren, Events abstrahieren, Flags/Support UI und Alerting-Runbook vorbereiten.

User/extern: Vendor-Auswahl/Accounts, Support-E-Mail/Domain und Datenschutzfreigabe.

Phase Gate

Produktionsfehler, Sync, Coach und Subscription sind sichtbar; Telemetrie enthält keine sensiblen Rohdaten.

Phase 09 - QA, Accessibility, Performance & Recovery

Ziel: Den Store-Build unter realistischen Langzeit-, Offline-, Accessibility- und Failure-Szenarien abnehmen.

Warum: Die Repo-Dokumentation nennt Device QA, große History, Accessibility und reale Migrationen ausdrücklich als offene Gates.

Planungsfenster: Woche 6-8

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
09.01	P0	L	Golden Device Matrix	Fresh install, upgrade, kill/reopen, offline, reconnect, account switch, coach, purchase, restore, permissions denied, timezone/DST.	Alle P0-Szenarien auf iOS und Android mit Evidence.
09.02	P0	M	Migration & Recovery Tests	Alte Beta-Datenbanken upgraden; Abbruch während Migration simulieren; Recovery definieren.	Kein Datenverlust bei Upgrade.
09.03	P0	M	Large Dataset Test	600-1000 Workouts, 10k+ Sets, lange Coach-History, viele Measurements/Template s.	Kernnavigation und History bleiben performant; Pagination/Optimierung falls nötig.
09.04	P1	M	VoiceOver/TalkBack	Labels, Fokusreihenfolge, Controls, dynamische Texte, Touch Targets.	Kernflows screenreader-bedienerbar.
09.05	P1	M	Reduced Motion / Large Text	Animationen respektieren prefers-reduced-motion; Layout bei großen Schriftgrößen.	Keine abgeschnittenen Kernaktionen.
09.06	P1	M	Low Network/Provider Failure	Timeout, 429, 5xx, offline; verständliche Retry-UX ohne Request-Storm.	Fehler werden kontrolliert behandelt.
09.07	P1	S	Low Storage & DB Failure	Schreibfehler/fehlender Speicher sinnvoll melden.	Kein stiller Datenverlust.

Agent kann: Fixture-Generatoren, Tests, Accessibility-Fixes, Performance-Profiling und Recovery-Code implementieren.

User/extern: Physische Testgeräte/Tester und manuelle Abnahme von UX/A11y.

Phase Gate

Release Candidate besteht dokumentierte P0 Device Matrix und Migrationstest.

Phase 10 - App Store / Play Store Submission

Ziel: Store-Metadaten, Privacy-Disclosures, Subscriptions und Review-Zugänge vollständig einreichen.

Warum: Ein funktionierender Build ist noch kein Store-Produkt. Review scheitert häufig an Metadaten, Privacy, Accountzugang oder unvollständigen Backend-Flows.

Planungsfenster: Woche 7-10

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
10.01	P0	M	Apple App Store Connect Setup	App Record, Categories, Age Rating, Support/Privacy URLs, Export Compliance, Review Notes, Demo Account.	Reviewer kann alle relevanten Features reproduzieren.

10.02	P0	M	Apple Privacy Details/Manifest	Privacy Labels aus Data Map; PrivacyInfo.xcprivacy/Required Reason APIs und SDK Manifests prüfen.	Keine widersprüchlichen Angaben oder Build-Warnungen.
10.03	P0	M	Google Play Console Setup	Data Safety, Health Apps Declaration, Content Rating, App Access, Store Listing, Production Track.	Deklarationen stimmen mit realem Verhalten/SDKs überein.
10.04	P0	M	Store Assets	Screenshots zeigen reale App; Feature Graphic/Descriptions/Keywords ohne unzulässige Claims.	Vollständige Assets für Zielgeräte und Sprachen.
10.05	P0	S	Review Account	Vorgefüllter Demo/Premium-Account mit History, Plans, Measurements und Coach.	Reviewer muss nicht erst Daten erzeugen.
10.06	P0	M	TestFlight / Closed Testing	RC an interne/externe Tester; Android erforderliche Testdauer einhalten.	Keine P0 Bugs mehr; Release Notes gepflegt.
10.07	P0	S	Backend Review Freeze	Während Review keine breaking Backendänderung; Uptime sicherstellen.	Review kann jederzeit auf funktionierende Services zugreifen.

Agent kann: Store-Metadatenentwürfe, Privacy-Fragebogen aus Data Map, Review Notes, Screenshotspec und Buildchecks vorbereiten.

User/extern: Store Console Eingaben, rechtliche/steuerliche Agreements, Upload/Submit-Freigabe.

Phase Gate

Alle Store-Formulare konsistent; Release Candidate ist identisch mit getestetem Build.

Phase 11 - Launch, Release Day & First 30 Days

Ziel: Kontrolliert ausrollen, Kosten/Stabilität überwachen und nur datenbasiert nachsteuern.

Warum: Der erste kommerzielle Monat entscheidet, ob technische Probleme, AI-Kosten oder schlechter Funnel früh erkannt werden.

Planungsfenster: Launch + 30 Tage

ID	Prio	Aufwand	Aufgabe	Maßnahme	Definition of Done
11.01	P0	S	Staged Rollout	iOS/Android nicht unnötig sofort maximal ausrollen; Monitoring während jeder Stufe.	Stop/Rollback-Kriterien sind definiert.
11.02	P0	S	Release-Day Dashboard	Crashes, API error rate, sync failures, purchases, restore, AI spend, trial starts.	Alle kritischen Signale an einem Ort.
11.03	P0	S	Incident Runbook	Coach kill switch, subscription incident, DB issue, privacy incident, bad release.	Konkrete Owner und Reihenfolge für Reaktion.
11.04	P1	M	30-Day KPI Review	Activation, first/second workout, D1/D7/D30, trial start, trial-to-paid, churn, ARPU, AI cost/paid user.	Jede Produktänderung wird an einer KPI-Hypothese aufgehängt.

11.05	P1	M	Support Triage	Bugs nach severity; keine Feature-Wunsch-Flut in V1.0.x.	P0/P1 Bugs priorisiert, Wünsche in Post-Launch-Backlog.
11.06	P2	M	Conversion Experiments	Paywall Copy/Order, Trial, Onboarding steps, annual emphasis mit kontrollierten Experimenten.	Nur ein klarer Experimentfaktor pro Test.
11.07	P3	L	Neue Produktbereiche	Nutrition, Running, Social etc. erst nach belastbarem Core-Retention-/Revenue-Signal.	Roadmap basiert auf Daten, nicht auf Feature-FOMO.

Agent kann: Dashboardspec, Runbooks, KPI-Abfragen, Bugs und kleine Release-Hotfixes vorbereiten.

User/extern: Rollout-Freigaben, Pricing/Marketing-Entscheidungen und Support-Priorisierung.

Phase Gate

30 Tage ohne ungeklärte kritische Security/Data-Loss/Subscription-Probleme; Unit Economics beobachtbar.

6. Security & Data Integrity Deep Dive

Für diese App ist Datenintegrität ein Produktfeature. Ein Nutzer verzeiht eine kleine Animation eher als den Verlust von zwei Jahren Trainingshistorie. Deshalb wird die Release-Reihenfolge explizit nach Data Integrity > Subscription Integrity > Security/Privacy > Crash Stability > Performance > UX Polish > neue Features sortiert.

6.1 Secrets und Client Boundary

- Provider-Secrets niemals in EXPO_PUBLIC_* oder Mobile-Bundle.
- Git-History und alte Branches auf geleakte Keys prüfen; kompromittierte Keys rotieren.
- Service-Role/DB-Admin/Webhook-Secrets nur in serverseitigen Secret Stores.
- Mobile-Logs dürfen keine Tokens oder Authorization Header enthalten.

6.2 Auth und sichere Tokens

- Refresh-/Session-Tokens in OS-geschütztem Secure Storage.
- Accountwechsel muss lokale Partitionen sauber trennen.
- Password reset / email verification / deep links auf echten Geräten testen.
- Optional später MFA; für V1 mindestens robuste Session-Invalidierung und Account Delete.

6.3 RLS und IDOR

Jede user-owned Tabelle muss explizit beweisen, dass Account A niemals Rows von Account B lesen, schreiben oder löschen kann. Die wichtigsten Tests sind negative Tests. Nicht nur "mein User kann seine Daten laden", sondern "fremde UUID, fremder Row-Key, manipulierte Request-Parameter und Service-Wrapper führen sicher zu Deny".

6.4 Offline/Online Sync

- Outbox-Operationen idempotent machen.

- Revision/updated_at alleine reicht bei komplexen Konflikten oft nicht; klare Konfliktstrategie dokumentieren.
- Deletes über Tombstones oder serverseitig nachvollziehbare Delete-Events synchronisieren.
- Retry Backoff und Dead Letter/diagnostic state für dauerhaft fehlerhafte Mutationen.
- Accountwechsel/Logout darf fremde Outbox-Einträge nicht erneut senden.

6.5 Dependency Findings

Der Audit verweist auf zahlreiche Dependency-Audit-Findings. Diese Zahl ist kein automatischer Beweis für ausnutzbare Produktlücken, aber ein Launch-Gate für Triage. Für jedes Finding werden Production Reachability, Fix-Verfügbarkeit, Exploit-Voraussetzungen, Mitigation und finale Entscheidung dokumentiert.

Finding-Klasse	Entscheidung
Production reachable + Fix vorhanden	Upgrade/Fix vor Release
Production reachable + kein Fix	Mitigation oder Dependency ersetzen; Risiko explizit abnehmen
Build/CLI only	Dokumentieren und Build-Exposure prüfen
False positive / unreachable	Evidence dokumentieren, nicht einfach ignorieren

7. Production Backend & AI Coach

Der Coach ist ein Differenzierungsfeature, aber auch der größte variable Kosten- und Datenfluss. Production muss jeden Request durch eine serverseitige Kontrollkette führen, bevor ein externer Modellanbieter Kosten erzeugt.

22. Session verifizieren
23. Premium-/Feature-Entitlement prüfen
24. Input/Media-Größe validieren
25. User-/Tages-/Monatsquota prüfen
26. Globales Budget / Emergency Stop prüfen
27. Nur notwendigen Kontext zusammenstellen
28. Freigegebenen Provider/Modellpfad wählen
29. Request mit Timeout ausführen
30. Response validieren/safety post-processen
31. Usage/Kostenmetadaten ohne sensitive Payload protokollieren

7.1 Distributed Limits

Prozesslokale Maps sind in Serverless-Umgebungen nicht ausreichend. Mehrere Instanzen würden getrennte Limits sehen. Daher zentraler Counter in Redis/Upstash oder PostgreSQL/RPC. Vision, Audio und schwere Plan-Generierungen benötigen separate Limits, weil ihre Kostenprofile anders sind.

7.2 Context Minimization

Eine Frage nach Brust-Volumen braucht nicht automatisch Körpergröße, Geschlecht, alle 800 Übungen und komplette Measurements. Ein Query-spezifischer Context Builder senkt Tokenkosten, Latenz und Datenschutzrisiko gleichzeitig.

7.3 OpenRouter / OpenAI / Gemini

Der Audit kommt nicht zu dem Ergebnis, dass kommerzielle Nutzung grundsätzlich verboten wäre. Die kritische Frage ist vielmehr die konkrete Datenkette: eigenes Backend -> OpenRouter -> ausgewählter Provider -> Modell. Für sensible Fitness-/Gesundheitsdaten müssen Terms, Data Retention, Training Policy, DPA/Processor-Rolle, Region und Subprozessoren pro produktivem Pfad geprüft und dokumentiert werden. Weniger Prozessoren vereinfachen die Datenschutzkette; OpenRouter bietet dafür Flexibilität und Failover. V1 kann OpenRouter beibehalten, wenn Provider und Data Policies explizit gelockt werden.

7.4 Safety Boundary

- Coach klar als KI kennzeichnen.
- Fitness-/Wellness-Coaching statt Diagnose/Therapie.
- Bei Verletzungen, akuten Symptomen oder medizinischer Unsicherheit zu qualifizierter medizinischer Hilfe verweisen.
- Keine extremen oder gefährlichen Trainings-/Gewichtsverlustempfehlungen.
- Systemprompt allein reicht nicht; Tests und serverseitige Policies ergänzen.

8. Privacy, deutsches/EU-Recht und Health Data

Die App verarbeitet potentiell Kontakt-, Account-, Trainings-, Körper-, Leistungs-, Coach-, Bild- und Audiodaten. Körpermaße und abgeleitete Fitnessinformationen können je nach Kontext in den Bereich von Gesundheitsdaten fallen. Deshalb sollte die Architektur vorsichtshalber mit dem Schutzniveau sensibler Daten geplant werden, auch wenn die App als Fitness-/Wellness-Produkt und nicht als Medizinprodukt positioniert wird.

8.1 Data Map als Single Source of Truth

Datenkategorie	Zweck	Speicher	Empfänger	Retention/Control
E-Mail/Account	Login, Sync	Supabase Auth	Supabase	Accountdauer + Löschprozess
Workouts/History	Tracking/Progress	SQLite + Cloud	Supabase	bis Nutzer löscht/Account endet
Measurements	Progress	SQLite + Cloud	Supabase	besondere Schutzprüfung
Coach Prompt/Context	AI Coaching	Backend temporär + Providerpfad	OpenRouter/Provider	minimieren; Retention vertraglich prüfen
Images/Audio	Vision/Transcription	temporär	OpenRouter/Provider	kurze Retention, nur intentional
Purchase IDs	Entitlement	Store + Backend	Apple/Google/Revenue layer	gesetzlich/vertraglich erforderlich
Push Tokens	Notifications	Backend	Push provider	bis revoke/device invalid

8.2 Must-Haves

- Privacy Policy in App und über stabile öffentliche URL.
- Impressum/Anbieterkennzeichnung nach deutschem Recht.
- Terms of Use für Account, Subscription, AI/Fair Use, Fitness Disclaimer, IP und Kündigung.
- Account Delete in der App.

- Datenexport/Portabilität.
- AI Data Sharing transparent und vor erster Third-party-AI-Verarbeitung kontrollierbar.
- Processor/DPA-/Subprocessor-Register und Drittlandtransferprüfung.
- Retention-/Deletion-Konzept inkl. Backups und Logs.
- Apple Privacy Details und Google Data Safety aus derselben Data Map ableiten.

8.3 Nicht verwechseln

- Store-Anforderung ist nicht automatisch dasselbe wie gesetzliche Pflicht.
- Ein Fitnesscoach ist nicht automatisch ein Medizinprodukt; medizinische Claims/Diagnose/Therapie erhöhen aber das Risiko erheblich.
- Eine Privacy Policy ersetzt keine technische Datenminimierung und keine Account-Löschung.
- Ein Checkbox-Consent ersetzt nicht automatisch die Prüfung passender Rechtsgrundlagen.

Externe Prüfung empfohlen

Vor kommerziellem Launch Privacy Policy, Terms, Art.-9-Ansatz, AI-Drittanbieter-Flow und Verbrauchervertrags-/Abo-Texte einmal durch einen deutschen IT-/Datenschutzjuristen prüfen lassen.

9. Exercise Database & Asset Licensing

Die Exercise Library ist funktional wertvoll, aber der Audit konnte aus den öffentlich sichtbaren Projektdateien keinen belastbaren Provenienz-/Lizenznachweis für die 800+ Übungen samt Medien ableiten. Das ist ein Launch-Blocker, bis die Herkunft beweisbar ist.

Lizenz-Audit Workflow

32. Importquelle in Git-History, Scripts, alten Branches, JSON-Metadaten und Commit Messages suchen.
33. Exakte Dataset-Version/Commit und Download-Datum dokumentieren.
34. Lizenztext archivieren und Commercial Use, Modification, Redistribution und Attribution bewerten.
35. Daten und Medien getrennt prüfen - Bilder/Animationen/Beschreibungen können andere Rechte haben.
36. Anatomie-/Illustrations-/Sound-/Font-Lizenzen mit Rechnung oder Lizenznachweis archivieren.
37. THIRD_PARTY_NOTICES.md bzw. Software/Asset BOM im Repo pflegen.
38. Wenn Provenienz nicht beweisbar ist: Assets ersetzen oder saubere kommerzielle Lizenz beschaffen.

Ein mögliches Public-Domain-Dataset mit über 800 Übungen existiert (`yuhonas/free-exercise-db`), aber der Audit konnte nicht beweisen, dass genau dieses Dataset die Quelle des Repositories ist. Die Ähnlichkeit der Größenordnung ist kein Lizenzbeweis.

Asset	Beweis erforderlich
Exercise names/data	Quelle, Dataset-Version, Lizenz, erlaubte Nutzung
Descriptions	Urheberrechtliche Herkunft und Änderungsrecht
Images/GIF/Video	separate Media-Lizenz und Redistribution
Anatomy map	Lizenz/Rechnung und erlaubte kommerzielle Nutzung
Fonts/Icons	Lizenztext, Attribution falls nötig
Sounds	Quelle, kommerzielle App-Nutzung, Redistribution
Open-source libraries	Lizenzbedingungen und Third-party notices

10. Monetarisierung, Subscriptions und Unit Economics

Für digitale Premiumfunktionen innerhalb der iOS-App ist Apple In-App Purchase/StoreKit der risikoärmste Standardweg; für Google Play entsprechend Play Billing. Apple Pay ist nicht dasselbe wie In-App Purchase. Stripe sollte für eine spätere Website-/Web-Subscription genutzt werden, nicht als primärer V1-In-App-Checkout für digitale Features.

10.1 Empfohlene Free/Pro-Aufteilung

Free	Volt Pro
Workout Tracking	AI Coach
Exercise Library	Cloud Sync/Backup
Basic History	Advanced Analytics/Insights
Measurements	Advanced/Unlimited Programs
Achievements/Level	AI Program Generation / Premium Coach
Basis-Programme	Cross-device Premium Experience

Export, Account-Löschung, Privacy Controls, Support und gesetzlich notwendige Funktionen dürfen nicht paywalled werden.

10.2 Preis-Hypothese

Als Start-Hypothese aus dem Audit: ca. 9,99 EUR/Monat und 59,99-69,99 EUR/Jahr, 7 Tage Trial, Jahresabo prominent. Das ist kein garantiert optimaler Preis. Der Store muss den tatsächlich belasteten Gesamtbetrag klar zeigen; ein Monatsäquivalent ist nur sekundär.

10.3 Warum RevenueCat sinnvoll ist

- Abstrahiert StoreKit und Play Billing.
- Hilft bei Restore, Renewal, Cancellation, Grace, Refund und Cross-device Entitlements.
- Webhooks machen serverseitiges Entitlement praktikabler.
- Reduziert eigene Subscription-State-Machine.
- Neue Vendor-Abhängigkeit und laufende Kosten müssen trotzdem bewusst bewertet werden.

10.4 Unit Economics Formel

Net Revenue pro zahlendem Nutzer = Brutto-Abo - Umsatzsteuer/Storeanteil - AI-Kosten - Hosting/DB/Monitoring - Subscription-Vendor - Support/Refund-Risiko. Entscheidend ist nicht nur LLM-Preis pro Token, sondern AI-Kosten pro zahlendem Nutzer und Monat. Das Backend benötigt harte User-/Globalbudgets, damit Heavy User die Marge nicht zerstören.

11. Onboarding, Paywall und Activation

Das Onboarding sollte kein langes Tutorial sein, sondern ein kurzer Personalization Funnel. Ziel ist: Nutzer versteht den Nutzen, liefert nur relevante Daten, erlebt ein personalisiertes Ergebnis und sieht erst dann eine transparente Paywall.

Schritt	Inhalt	Regel
1 Value	Train smarter / Progress with purpose	Keine Permission, kein Login
2 Goal	Muscle / Strength / Calisthenics / Fat loss / General	produktrelevant
3 Experience	Beginner / Intermediate / Advanced	Coach-Kontext
4 Frequency	2-6+	Plan/Reminder-Kontext
5 Equipment	Gym / Home / Bodyweight / Minimal	Exercise/Plan-Kontext
6 Body data	Weight/Height/Sex/Units optional	Zweck erklären; datensparsam
7 Coach prefs	Programming/Progression/Technique/etc.	keine externe AI-Verarbeitung nötig
8 Result	Training profile ready	Value Reveal
9 Paywall	Trial + annual/monthly + free path	klarer Preis/Restore/Terms/Privacy
10 Account	erst wenn für Sync/Backup/Premium nötig	Guest Mode erhalten

Permissions werden kontextuell angefragt: Notification Permission erst nach verständlichem Pre-Prompt für Workout/Rest Reminder, Microphone erst beim Voice Coach, Photos erst beim Image Use Case.

12. Push, Haptik und Audio

Native Feel soll funktional sein, nicht dekorativ. Besonders Workout-Apps profitieren von lokalen Timern, präzisiertem haptischen Feedback und sehr sparsamen Sounds.

Moment	Empfehlung
Tab/Segment/Picker	Selection Haptic
Set abgeschlossen	Light/Medium impact
PR	Success haptic + optional kurzer Sound
Workout complete	Success haptic + kurzer Abschluss-Sound
Invalid input	Error haptic sparsam
Destructive confirmation	Warning haptic
Rest complete	Local notification + optional Sound
Workout reminder	Local/Server notification nach Preferences

Settings brauchen globale Toggles für Haptics/Sounds und granularere Notification-Kategorien. Marketing-/Product-Push wird separat opt-in behandelt und erhält Frequency Caps.

13. Analytics, Monitoring, Remote Config und Support

Nach Launch müssen technische und geschäftliche Signale sichtbar sein. Gleichzeitig bleibt Telemetrie metadata-only, wenn Rohdaten sensibel sind.

Kernmetriken

- Activation: onboarding_completed, first_workout_started/completed, second_workout.
- Retention: D1/D7/D30, workouts/user/week.
- Monetization: paywall_viewed, trial_started, trial_to_paid, annual_share, churn, refund rate, ARPU/LTV.
- AI Economics: AI requests/paid user, cost/paid user, vision/audio Anteil, quota hit rate.
- Quality: crash-free sessions, API 5xx, sync failure, migration failure, subscription webhook failure.

Nicht als normale Analytics Properties senden: Gewicht, Körperfett, Measurements, PR-Gewichte, Coach-Prompt, Verletzungs-/Gesundheitstexte, komplette Workouts oder Bilder.

Remote Config

- coach_enabled
- paywall_variant
- new_subscription_flow_enabled
- notification_campaign_enabled
- minimum_supported_version / maintenance flags

14. Native QA, Accessibility, Performance und Recovery

Der Release Candidate wird nicht nur gegen "Happy Path" getestet. Die eigentlichen Store-/Production-Bugs entstehen bei Upgrade, Backgrounding, Netzwerkwechsel, Permissions, großen Datenmengen und Accountwechsel.

Szenario	Plattform	Prio
Fresh install	iOS + Android	P0
Upgrade von Beta-Daten	iOS + Android	P0
Cold/warm start + OS kill	beide	P0
Offline -> Online	beide	P0
Account switch	beide	P0
2 Geräte / Sync Conflict	beide	P0
500-1000 Workouts / 10k+ sets	beide	P0
AI text/image/audio	beide	P0
Purchase/Restore/Cancel/Expiry	beide	P0
Permissions denied	beide	P0
Timezone/DST/German decimal	beide	P1
VoiceOver/TalkBack	beide	P1
Large text / reduced motion	beide	P1
Low storage / failed DB write	beide	P1

Provider timeout / 429 / 5xx	beide	P1
------------------------------	-------	----

15. iOS-/Android Store Submission

15.1 iOS

- Apple Developer Program / richtige Publisher Identity.
- App Store Connect Record, Bundle ID, Signing, EAS Production Build.
- App Name, Subtitle, Description, Keywords, Category, Age Rating.
- Screenshots mit realer App-Nutzung.
- Support URL, Privacy Policy URL, Terms.
- App Privacy Details aus Data Map.
- Privacy Manifest / Required Reason APIs / Third-party SDK manifests.
- Auto-renewable subscription metadata, Trial/Preis korrekt.
- Review Notes + Demo Account mit Premium, History, Plans und Measurements.
- TestFlight RC und stabile Production-Backends während Review.

15.2 Android

- Play Console Developer Account / Verification.
- AAB Signing/Package final.
- Store Listing, Feature Graphic, Screenshots.
- Data Safety und Privacy Policy.
- Health Apps Declaration für Fitness-App-Kontext.
- Content Rating, Target Audience, App Access.
- Play Billing Products/Subscriptions.
- Closed Testing / ggf. 12 Tester über 14 Tage bei betroffenen neuen persönlichen Accounts.
- Production Track erst nach RC-Abnahme.

16. Definition: Minimum Commercial Launch

Minimum Commercial Launch

Ein bezahlbares Produkt mit stabilem Tracker-Core, sicherer Datenhaltung, produktionsfähigem Coach, nativen Abos, transparentem Onboarding/Paywall, Legal/Privacy, Monitoring und Store-Abnahme. Nicht: maximale Featurezahl.

- Tracker Core stabil und offline nutzbar.
- Cloud/Account nur so weit, dass Sync/Backup vertrauenswürdig ist.
- AI Coach geschützt durch Auth, Entitlement, Quota, Budget und Consent.
- Free/Pro klar, native Billing vollständig.
- Delete/Export/Privacy/Legal vollständig.
- Exercise-/Asset-Rechte beweisbar.
- P0 QA und Store-Disclosures abgeschlossen.
- Monitoring und Kill Switch vorhanden.

17. Kosten- und Budgetsteuerung

Fixe Store-Kosten aus dem Audit: Apple Developer Program aktuell etwa 99 USD/Jahr bzw. lokaler Gegenwert; Google Play Developer Registrierung etwa 25 USD einmalig. Store-Provisionen und aktuelle Programme müssen zum Launch nochmals in den jeweiligen Portalen geprüft werden.

Für Infrastruktur sollte nicht mit einer scheinpräzisen Zahl geplant werden, solange echte Nutzung fehlt. Besser ist ein Budget Envelope mit harten Limits:

Kostenblock	V1 Steuerung
Supabase	kleiner Production-Tier; DB/Storage/Egress beobachten; Backups/PITR einplanen
Vercel/Backend	Function Requests/Duration/Media beobachten; Timeouts sauber konfigurieren
AI	pro User/Monat und globales Tages-/Monatsbudget; Text/Vision/Audio getrennt
Revenue/Subscription Vendor	aktuelles Pricing vor Vertrag prüfen; Marge in Unit Economics berücksichtigen
Monitoring/Analytics	datensparsamen Tier wählen; Eventvolumen begrenzen
Push	zunächst kostengünstige Standardinfrastruktur; keine unnötige Vendor-Komplexität
Legal	einmaliger professioneller Review als Launchbudget einplanen
Assets/Licensing	nur bei ungeklärter Provenienz oder Ersatzbedarf

Empfehlung für AI Budgeting: Starte konservativ und tracke reale mediane/95p AI-Kosten pro zahlendem Nutzer. Höhere Modellklassen nur für komplexe Aufgaben routen. Vision/Audio erhalten kleinere Kontingente. Ein globaler Emergency Stop ist Pflicht.

18. Release-Day Runbook und erste 30 Tage

Release Day - vor Freigabe

- Production build hash/version mit getestetem RC abgleichen.
- Backend health, DB migrations, RLS tests, AI kill switch, purchase webhooks prüfen.
- Privacy/Terms/Support URLs erreichbar.
- Testkauf + Restore kurz vor Release verifizieren.
- Alerts aktiv; On-call Kontakt/Owner fest.
- Staged rollout/Release plan dokumentiert.

Release Day - nach Freigabe

- Crash rate und API/Sync/Coach Errors eng überwachen.
- Purchase/Restore/Webhook Events beobachten.
- AI Spend und Quota-Hits beobachten.
- Support Inbox priorisieren.
- Keine großen Feature Deployments am selben Tag.

Erste 7 Tage

- P0/P1 Bugs fixen, keine Roadmap-Erweiterung.
- Activation und First/Second Workout Funnel prüfen.
- Trial Starts und technische Purchase Drop-offs analysieren.
- Coach Fehler/Latency/Cost pro User messen.
- Unklare Privacy-/Deletion-/Supportfälle sofort eskalieren.

Tag 8-30

- D7/D30 Retention und Workouts/User/Woche analysieren.
- Trial-to-paid, annual share, churn/refund beobachten.
- Ersten kontrollierten Paywall/Onboarding-Test nur bei stabiler Technik durchführen.
- AI Quotas anhand echter Kosten kalibrieren.
- Post-Launch-Backlog priorisieren; neue Großfeatures nur mit Retention-/Revenue-Hypothese.

19. Master Go-Live Checklist

Prio	Bereich	Gate
P0	Native	Echter iOS-Build auf physischem Gerät
P0	Native	Echter Android-Build auf physischem Gerät
P0	Identity	Bundle ID / Package / Scheme / Brand final
P0	Security	Keine Provider-/Service-Secrets im Client oder Git
P0	Security	Secure token storage
P0	Security	RLS Cross-Account Tests
P0	Data	Offline/Online ohne Datenverlust
P0	Data	Zwei-Geräte-Konflikte ohne stillen Datenverlust
P0	Data	Account löschen löscht Cloud + Auth + lokale Daten
P0	Data	Vollständiger Datenexport
P0	Backend	Production HTTPS Coach endpoint
P0	Backend	Distributed AI rate limits
P0	Backend	Global + per-user cost guard
P0	Backend	Premium entitlement serverseitig
P0	AI	Freigegebene Provider/Modelle dokumentiert
P0	AI	AI consent + transparency
P0	Licensing	Exercise DB Provenance und Commercial Rights
P0	Licensing	Bilder/Anatomie/Fonts/Icons/Sounds Lizenz-BOM
P0	Legal	Privacy Policy live
P0	Legal	Impressum live
P0	Legal	Terms live

P0	Legal	Processor/DPA Register
P0	Monetization	StoreKit purchase/restore
P0	Monetization	Google Billing purchase/restore
P0	Monetization	Renewal/cancel/expiry/refund getestet
P0	Monitoring	Crash/Error/Sync/AI spend Monitoring
P0	Store	Apple Privacy Details / Manifest geprüft
P0	Store	Google Data Safety + Health Declaration
P0	Store	Reviewer Demo Account
P0	QA	Migration von Beta-Daten getestet
P0	QA	Release Candidate P0 Device Matrix bestanden
P1	UX	Onboarding + personalized result + fair paywall
P1	UX	Empty/Error/Offline States
P1	Native Feel	Push Preferences + local reminders
P1	Native Feel	Haptic Service + Settings
P1	Native Feel	Audio Service + Settings
P1	Accessibility	VoiceOver/TalkBack/Large Text
P1	Analytics	Event taxonomy ohne Health payloads
P1	Operations	Remote config / kill switches
P1	Support	Support/FAQ/feedback path

20. Offene Entscheidungen

Thema	Entscheidung vor Umsetzung/Launch
Brand	Volt vs Volt Performance; finaler Display Name; Domain/Support URLs.
Publisher identity	Privater Developer-Account vs Organization/Unternehmensauftritt.
Freemium	Welche Kernfunktionen bleiben dauerhaft kostenlos? Empfehlung: Tracking, Library, Basis-History/Measurements; Pro: AI, Cloud, Advanced Analytics/Programs.
Pricing	Start-Hypothese aus Audit: ca. 9,99 EUR monatlich und 59,99-69,99 EUR jährlich mit 7 Tagen Trial. Vor Anlage im Store final entscheiden.
Subscription layer	RevenueCat empfohlen vs komplett eigene StoreKit/Play-Abstraktion.
AI provider policy	OpenRouter beibehalten und Provider locken vs direkte Provider-APIs für sensiblere Datenflüsse.
Production hosting	Bestehenden Vercel-orientierten Coach-Handler zunächst beibehalten vs später Edge/anderen Runtime-Wechsel.
Analytics/Crash vendor	Vendor auswählen unter Datenschutz-/DPA-Anforderungen.
Legal review	Kanzlei/Datenschutzexperte für finalen Review benennen.

Exercise assets	Falls Provenienz nicht beweisbar: nur Daten ersetzen, Medien ersetzen oder kommerzielle Lizenz erwerben.
-----------------	--

21. Quellen und Audit-Annahmen

Diese Roadmap basiert auf der zuvor erstellten Deep-Research-Analyse des öffentlichen Repositories und den dort geprüften offiziellen bzw. primären Quellen. Repo- und Richtlinienstände können sich ändern; vor tatsächlicher Store-Einreichung sollten dynamische Store-/Providerregeln erneut gegen den dann aktuellen Stand geprüft werden.

ID	Quelle	URL
S1	Repository	https://github.com/knrds/fitness-tracker
S2	ARCHITECTURE.md	https://github.com/knrds/fitness-tracker/blob/main/ARCHITECTURE.md
S3	ROADMAP.md	https://github.com/knrds/fitness-tracker/blob/main/ROADMAP.md
S4	KNOWN_ISSUES.md	https://github.com/knrds/fitness-tracker/blob/main/KNOWN_ISSUES.md
S5	SECURITY.md	https://github.com/knrds/fitness-tracker/blob/main/SECURITY.md
S6	BACKEND.md	https://github.com/knrds/fitness-tracker/blob/main/BACKEND.md
S7	IOS_SETUP.md	https://github.com/knrds/fitness-tracker/blob/main/IOS_SETUP.md
S8	Mobile package.json	https://github.com/knrds/fitness-tracker/blob/main/apps/mobile/package.json
S9	Apple App Review Guidelines	https://developer.apple.com/app-store/review/guidelines/
S10	Apple Auto-renewable Subscriptions	https://developer.apple.com/app-store/subscriptions/
S11	Apple App Privacy	https://developer.apple.com/help/app-store-connect/manage-app-information/manage-app-privacy/
S12	Google Play Payments Policy	https://support.google.com/googleplay/android-developer/answer/10281818?hl=en
S13	Google Play Data Safety	https://support.google.com/googleplay/android-developer/answer/10787469?hl=en
S14	Google Health Apps Policies	https://support.google.com/googleplay/android-developer/answer/13996367?hl=en
S15	GDPR / DSGVO	https://eur-lex.europa.eu/eli/reg/2016/679/oj
S16	DDG §5	https://www.gesetze-im-internet.de/ddg/_5.html
S17	BGB §327	https://www.gesetze-im-internet.de/bgb/_327.html
S18	BGB §312k	https://www.gesetze-im-internet.de/bgb/_312k.html
S19	EU AI Act	https://eur-lex.europa.eu/eli/reg/2024/1689/oj
S20	OpenRouter Terms	https://openrouter.ai/terms
S21	OpenRouter Privacy	https://openrouter.ai/privacy
S22	OpenAI Services Agreement	https://openai.com/policies/services-agreement/

S23	Gemini Developer API	https://ai.google.dev/
S24	free-exercise-db	https://github.com/yuhonas/free-exercise-db

Wichtig: Aus dem Audit nicht verifizierbare Punkte - insbesondere tatsächliche Production-Credentials, abgeschlossene DPA/AVV, Rechnungen/Lizenznachweise, echte Store-Accountzustände und juristische Freigaben - werden in diesem Paket absichtlich als User-/External-Actions behandelt und nicht als erledigt angenommen.

Finales Go-Live-Prinzip

Wenn du bei einem P0-Gate nicht beweisen kannst, dass es erledigt oder nicht anwendbar ist, ist es kein "später"-Punkt, sondern ein Release-Blocker. Genau diese Disziplin verhindert den typischen Fehler, eine optisch fertige Beta zu früh zu monetarisieren.